

Security+ 1.4 · Certificates

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.4 — Certificates (14:38)** · [Vídeo no YouTube ↗](#)

Resumo da Aula: Certificado digital: arquivo assinado pela CA (Certificate Authority) que liga domínio a chave pública. Self-signed = tu mesmo assina (confiança própria, não deve ir pro público). CSR = Certificate Signing Request (tu manda a chave pública + identidade pra CA assinar). CRL (lista de revogados) / OCSP (verificação online) / OCSP stapling (servidor anexa resposta).

Highlights que a prova cobra

- CA assina o certificado — cadeia de confiança root CA → intermediária → leaf
- CSR = requisição de assinatura: contém a chave pública + identidade
- CRL/OCSP/stapling = como o browser checa se certificado foi revogado

Dicas de prova & Cenários Típicos

- 'contains public key and identity, signed by CA' = certificate
- 'revocation checking method with online query' = OCSP

Cenário clássico de exame: Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado não é confiável' — self-signed ou expirado/revogado.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 1.4)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Certificates) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Criptografia Simétrica (AES-256, ChaCha20):** Usa uma única chave idêntica para cifrar e decifrar. Excelente para confidencialidade de grandes volumes (BitLocker, banco de dados, túneis VPN). **Atenção de prova:** cifras simétricas NÃO oferecem não-repúdio quando a chave é compartilhada.
- **Criptografia Assimétrica (RSA, ECC, Ed25519):** Usa par de chaves matemáticas: a Chave Pública é distribuída livremente; a Chave Privada é mantida em segredo absoluto pelo titular. Assinar o hash com a chave privada garante **Não-repúdio e Autenticidade**. Cifrar com a chave pública do destinatário garante **Confidencialidade**.
- **Hashing (SHA-256, SHA-3) vs. HMAC:** Hash puro é função matemática unidirecional sem chave, garantindo apenas integridade (qualquer um pode recalculá-lo de um dado adulterado). O HMAC combina hash com chave simétrica secreta, provendo integridade e autenticação mútua entre sistemas conhecidos.
- **TSA (Time Stamping Authority - RFC 3161) e LTV:** Entidade confiável que assina o hash com data/hora auditada, provando o momento exato em que o documento existiu e garantindo validação de longo prazo (LTV) mesmo após a expiração de certificados.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Hash puro NÃO fornece não-repúdio.
- AES com chave compartilhada destrói o não-repúdio.
- Políticas em papel e termos de adesão são controles puramente administrativos; não bloqueiam ataques em tempo de execução.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. No TLS/HTTPS, o certificado do site serve pra:

- A)** Provar a identidade do servidor e habilitar a troca segura de chave
- B)** Criptografar o disco
- C)** Bloquear malware
- D)** Fazer backup

2. Em uma infraestrutura PKI, qual componente é responsável por validar e revogar certificados digitais?

- A)** RA (Registration Authority)
- B)** CA (Certificate Authority)
- C)** CRL (Certificate Revocation List)
- D)** OCSP (Online Certificate Status Protocol)

3. Uma característica de HASH (diferente de criptografia) é que ele:

- A)** Pode ser revertido com a chave
- B)** É de mão única (não reversível)
- C)** Sempre encurta o texto pela metade
- D)** Precisa de par de chaves

4. Qual tipo de criptografia usa pares de chaves pública e privada?

- A)** Hashing
- B)** Criptografia simétrica
- C)** Criptografia assimétrica
- D)** Steganografia

5. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'CA assina o certificado — cadeia de confiança root CA → intermediária → leaf'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: CA assina o certificado — cadeia de confiança root CA → intermediária → lea...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'CSR = requisição de assinatura: contém a chave pública + identidade'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: CSR = requisição de assinatura: contém a chave pública + identidade...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'CRL/OCSP/stapling = como o browser checa se certificado foi revogado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: CRL/OCSP/stapling = como o browser checa se certificado foi revogado...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'contains public key and identity, signed by CA' = certificate'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'contains public key and identity, signed by CA' = certificate...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'revocation checking method with online query' = OCSP'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'revocation checking method with online query' = OCSP...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado não é confiável' — self-signed ou expirado/revocado.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado ...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) A — Provar a identidade do servidor e habilitar a troca segura de chave.

✓ **Por que está certa:** O certificado (assinado por uma CA) prova que o servidor é quem diz ser e habilita a troca segura da chave da sessão.

✗ **Por que as outras estão erradas:**

- *Criptografar o disco:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Bloquear malware:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Fazer backup:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) B — CA (Certificate Authority).

✓ **Por que está certa:** A CA (Autoridade Certificadora) emite, valida e revoga certificados. A RA apenas verifica identidades, enquanto CRL e OCSP são mecanismos de verificação de revogação.

✗ **Por que as outras estão erradas:**

- *RA (Registration Authority):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *CRL (Certificate Revocation List):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *OCSP (Online Certificate Status Protocol):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) B — É de mão única (não reversível).

✓ **Por que está certa:** Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade.

✗ **Por que as outras estão erradas:**

- *Pode ser revertido com a chave:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Sempre encurta o texto pela metade:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Precisa de par de chaves:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

4) C — Criptografia assimétrica.

✓ **Por que está certa:** Criptografia assimétrica (como RSA, ECC) usa par de chaves matematicamente relacionadas: pública para criptografar e privada para descriptografar, ou vice-versa para assinatura.

✗ **Por que as outras estão erradas:**

- *Hashing:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Criptografia simétrica:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Steganografia:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

5) A — Implementar a solução correspondente: CA assina o certificado — cadeia de confiança root CA → intermediária → leaf....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): CA assina o certificado — cadeia de confiança root CA → intermediária → leaf.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: CSR = requisição de assinatura: contém a chave pública + identidade....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): CSR = requisição de assinatura: contém a chave pública + identidade.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: CRL/OCSP/stapling = como o browser checa se certificado foi revogado....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): CRL/OCSP/stapling = como o browser checa se certificado foi revogado.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: 'contains public key and identity, signed by CA' = certificate....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): 'contains public key and identity, signed by CA' = certificate.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: 'revocation checking method with online query' = OCSP....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): 'revocation checking method with online query' = OCSP.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado não é confiável' — self-signed ou expirado/revocado..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

